Malicious software and adversarial behaviours

6COSC019W- Cyber Security

Dr Mohemmed Sha Mohamed Kunju

March 09, 2026

Prepared by Dr Ayman El Hajjar

UNIVERSITY OF WESTMINSTER

Overview

1. Malicious Software
2. Malware Lifecycle & Classifications
3. Malware Types
4. Payload Classifications
5. Social Engineering
6. Threats & Countermeasures

What is Malware

NIST 800-83 defines Malware as:
"A program that is inserted into a system, usually covertly, with the intent of compromising the confidentiality, integrity, or availability of the victim's data, applications, or operating system or otherwise annoying or disrupting the victim."

NCSC defines Malware as:
"a term that includes virus, trojans, worms or any code or content that could have an adverse impact on organisations or individuals.."

Malicious Code and Activity

- Any program that carries out actions that you (user/System) did not intend to do is considered to be a Malicious software (Malware)
- Malicious code attacks one or more of the three information security properties:
  - **Confidentiality**: Leaks secrets (e.g., 2023 data breach).
  - **Integrity**: Alters records (e.g., falsified logs).
  - **Availability**: Crashes systems (e.g., ransomware).

Malware Lifecycle

- Malware operates in three phases —how it attacks and persists:

  Infection: How it gets in.

  ↓↓↓↓↓↓

  Execution: When and how it runs.

  ↓↓↓↓↓↓

  Payload: What it does.

- The original approach to classify Malware focuses on its lifecycle, and how they spread or propagate through an information system environment to reach the desired target/s

Malware Classification approach

- A more conventional approach was developed to consider all dimensions of Malware in order to classify them.
- This approach is used by the NCSC and it contains the following dimensions:
  - How it installs itself
  - Where it installs itself
  - How it is triggered
  - Outside communication?

How it installs itself

- Malware are categorised based on which layer of the system stack the Malware is installed and run on
- This could be the Firmware, The Boot sector, The Operating System, The Driver, The API, or The User Application.
- We can categorise the installation locations into two categories:
  - **Independent Malware or standalone** is a complete program that can run on its own once it is installed on a compromised machine and executed.
  - **Host dependent Malware** requires a host program to run. It cannot run independently, but infect a program on a computer by inserting its instructions into the program or modifying the host code.

Where it installs itself

- Malware are also categories on the location of where it installs itself and whether it persists after a reboot or not.
- Persistent or Transient
  - **Persistent Malware** are installed in persistent storage such as a file system (your hard drive) or an external storage device. They can be either standalone or host independent.
  - **Transient Malware** are installed in volatile memory such as as RAM memory.
- Note that the "How it installs itself" dimension generally only applies to only persistent Malware (Ones that requires installation)

Malware Classification approach

- How it is triggered
  - **Auto-spreading Malware** runs and then looks for other vulnerable machines on the Internet, compromises these machines and installs itself on them;
  - **User-activated Malware** runs on a computer only because a user accidentally downloads and executes it, e.g., by clicking on an attachment or URL in a received email.

Malware Classification approach

- Static or dynamically updated
  - Malware that are supported by an infrastructure and can still communicate with such infrastructure are dynamically updated with new version regularly.
  - Static Malware or one time Malware has no infrastructure to support it and are standalone software with no network connection to an external infrastructure
- Act alone or coordinated attack
  - **Act alone Malware** are isolated Malware that runs on their own. They do not participate in a larger scale attack. Such Malware usually have a specific target.
  - **Coordinated Malware** are attacks that contribute to a larger scale attack as on their own they will not cause much damage. For example, collectively several devices infected by such Malware can cause networks or systems to crash (DDoS).

Malware Contents

- Malware are divided into two parts:
  - Infection mechanism: How it propagates
  - The Payload: what happens after it reaches the target

Propagation mechanism includes	• Infection of existing content by viruses that is subsequently spread to other systems • Exploit of software vulnerabilities by worms or drive-by-downloads to allow the malware to replicate • Social engineering attacks that convince users to bypass security mechanisms to install trojans or to respond to phishing attacks
Payload actions performed by malware once it reaches a target system can include	• Corruption of system or data files • Theft of service/make the system a zombie agent of attack as part of a botnet • Stealthing/hiding its presence on the system

Virus

- Piece of software that infects programs
  - Modifies them to include a copy of the virus
  - Replicates and goes on to infect other content
  - Easily spread through network environments
- When attached to an executable program a virus can do anything that the program is permitted to do
  - Executes secretly when the host program is run
- Specific to operating system and hardware
  - Takes advantage of their details and weaknesses

Virus Components

Infection Mechanism

- Means by which a virus spreads or propagates
- Also referred to as the infection vector

Trigger

- Event or condition that determines when the payload is activated or delivered
- Sometimes known as a logic bomb

Payload

- What the virus does (besides spreading)
- May involve damage or benign but noticeable activity

VIRUS PHASES

Dormant phase	• Virus is idle • Will eventually be activated by some event • Not all viruses have this stage
Triggering phase	• Virus is activated to perform the function for which it was intended • Can be caused by a variety of system events
Propagation phase	• Virus Places a copy of itself into other programs or into certain system areas on the disk • May be identical to the propagating version • Each infected program will now contain a close of the virus which will itself enter a propagation phase
Execution phase	• Virus function is perform (Objective) • May be harmless or damaging

Virus Classifications: By Targets

Boot sector infector

- Infects a master boot record or boot record and spreads when a system is booted from the disk containing the virus

File Infectors

- Infects files that the operating system or shell considers to be executable

Macro virus

- Infects files with macro or scripting code that is interpreted by an application

Multipartite virus

- Infects files in multiple ways

Virus Classifications: By concealment strategy

Encrypted virus

- A portion of the virus creates a random encryption key and encrypts the remainder of the virus

Stealth virus

- A form of virus explicitly designed to hide itself from detection by anti-virus software

Polymorphic virus

- A virus that mutates with every infection

Metamorphic virus

- A virus that mutates and rewrites itself completely at each iteration and may change behaviour as well as appearance

Malvertising

- Malvertising are malware placed via ads, without compromising websites
- Attackers pay for ads on target sites, embedding Malware
- Visitors get infected by malicious ads
- Malware may be dynamically generated to evade detection
- Popular due to ease of placement and difficulty of tracking
- Ads can be short-lived, timed for targeted browsing periods

Clickjacking

- also known as user-interface (UI) redress attack
- Keystrokes can be hijacked
  - Users may think they're typing passwords but are entering them into an invisible frame
- Attackers collect infected users' clicks
  - Force users to change settings or visit malicious sites
  - Use transparent/opaque layers to trick users into clicking on unintended buttons/links
  - Hijack clicks meant for one page, route to another

Macro and Scripting virus

- Macro virus infect scripting code used to support active content in a variety of user document types
- Are threatening for a number of reasons:
  - Is platform independent
  - Infect documents, not executable portions of code
  - Are easily spread
  - Because they infect user documents rather than system programs, traditional file system access controls are of limited use in preventing their spread, since users are expected to modify them
  - Are much easier to write or to modify than traditional executable virus

Macro and Scripting virus: Trusted Download?

Active Content virus

- Active content
  - Refers to dynamic objects that do something when the user opens a webpage (ActiveX, Java, JavaScript, VBScript, macros, browser plugins, PDF files, and other scripting languages)
  - Has potential weaknesses that Malware can exploit
- Active content threats are considered mobile code because these programs run on a wide variety of computer platforms
- Users download bits of mobile code, which gain access to the hard disk and do things like fill up desktop with infected file icons

Worms

- Program that actively seeks out more machines to infect and each infected machine serves as an automated launching pad for attacks on other machines
- Exploits software vulnerabilities in client or server programs
- Usually carries some form of payload

email	• Worm e-mails a copy of itself to other systems • Sends itself as an attachment via an instant message service
File sharing	• Creates a copy of itself or infects a file as a virus on removable media
Remote execution capability	• Worm executes a copy of itself on another system
Remote file access or transfer capability	• Worm uses a remote file access or transfer service to copy itself from one system to the other
Remote login capability	• Worm logs onto a remote system as a user and then uses commands to copy itself from one system to the other.

Worm Types

1. **Multiplatform**: Worms are not Operating System specific.
2. **Multi-exploit**: Worms penetrate systems using a variety of methods
3. **Ultrafast spreading**: Exploit various techniques to optimize the rate of spread of the worm
4. **Polymorphic**: To evade detection, skip past filters, and foil real-time analysis, worms adopt the virus polymorphic technique.
5. **Metamorphic**: In addition to changing their appearance, metamorphic worms have a collection of behaviour patterns that are unleashed at different stages of propagation.
6. **Zero-day exploit** : To achieve maximum surprise and distribution, a worm should exploit an unknown vulnerability that is only discovered by the general network community when the worm is launched.

Rootkits

- Type of Malware that modifies or replaces one or more existing programs to hide the fact that a computer has been compromised
- Modify parts of the operating system to conceal traces of their presence
- Provide attackers with access to compromised computers and easy access to launching additional attacks
- Difficult to detect and remove

Rootkits Classification Characteristics

1. **Persistent**: Activates at every boot; stores code in the registry or file system for auto-execution.
2. **Memory-based**: Exists only in memory; does not survive reboot, making it harder to detect.
3. **User mode**: Intercepts and modifies API call results.
4. **Kernel mode**: Intercepts kernel-level API calls; can hide malware processes.
5. **External mode**: Located outside the normal system operation, like in BIOS; can access hardware directly.

Payload classes

- Payload are classified based on the damage or threat they bring to the system
- The different classes of payload are:

System Corruption

- Causes damage to physical equipment such as Stuxnet worm
  Targets specific industrial control system software
- There are concerns about using sophisticated targeted Malware for industrial sabotage

Payload classes

Attack Agents Bots

- Takes over another Internet attached computer and uses that computer to launch or manage attacks
- **Botnet** - collection of bots capable of acting in a coordinated manner
  For example DDoS botnets

Remote Control Facility

- Typical means of implementing the remote control facility is on an IRC server
  Bots join a specific channel on this server and treat incoming messages as commands

Payload classes

Information Theft-Keyloggers and Spyware

- **Keyloggers**
  Captures keystrokes & enables monitoring all entries
- **Spyware**
  Subverts the compromised machine to allow monitoring of a wide range of activity on the system

Information Theft- Phishing

- **Phishing** exploits social engineering to leverage the user's trust by masquerading as communication from a trusted source
  Include a URL for a fake Website in a spam e-mail
  Attacker exploits the account using the captured credentials

Payload classes

Stealthing Backdoor

- Secret entry point into a program allowing the attacker to gain access and bypass the security access procedures, also called a **trapdoor**.
- Difficult to implement operating system controls for backdoors in applications

Stealthing Rootkit

- Set of hidden programs installed on a system to maintain covert access to that system with administrator (or root) privilege
  allow to add/change programs & files, to monitor processes, to send and receive network traffic, and to obtain backdoor access when needed

Social Engineering

"Tricking" users to assist in the compromise of their own systems

Spam	• Unsolicited bulk e-mail • Significant carrier of malware • Used for phishing attacks
Trojan horse	• Program or utility containing harmful hidden code • Used to accomplish functions that the attacker could not accomplish directly
Mobile phone Trojans	• First appeared in 2004 (Skuller) • Target is the smartphone

Malware Countermeasure Approaches

- Ideal solution to the threat of Malware is prevention

Four main elements of prevention

- Policy
- Awareness
- Vulnerability mitigation
- Threat mitigation

- If prevention fails, technical mechanisms can be used to support the following threat mitigation options:
  - Detection
  - Identification
  - Removal

Generations of Anti-Virus Software

First generation	• Requires a malware signature to identify malware • Limited to detecting known malware
Second generation	• Uses heuristic rules for probable malware detection • Integrity checking as an alternative approach
Third generation	• Memory-resident programs identifying malware by actions, not structure
Fourth generation	• Combines various anti-virus techniques • Includes scanning, activity traps, and access control

References

- The lecture notes and contents were compiled from my own notes and from various sources.
- Figures and tables are from the recommended books
- **The lecture notes are very detailed. If you attend the lecture, you should be able to understand the topics.**
- **You can use any of the recommended readings! You do not need to read all the chapters!**
- **Recommended Readings note:** Focus on what was covered in the class.
  - Chapter 5- Malware, Computer Security Fundamentals
  - Chapter 8- Malicious software and Attack Vectors, Fundamentals of Information Systems Security